

11.5 IT-Sicherheitsrichtlinien

IT-Sicherheitsrichtlinien sind verbindliche Vorgaben eines Unternehmens zur Gewährleistung von Verfügbarkeit, Vertraulichkeit und Integrität von IT-Systemen und Daten. Sie definieren Regeln und Maßnahmen zum Schutz vor Cyberangriffen, Datenverlust und unbefugtem Zugriff.

Inhalte einer IT-Sicherheitsrichtlinie

1. Zugriffs- und Berechtigungskonzepte
 - Nutzung von starken Passwörtern und Multi-Faktor-Authentifizierung (MFA)
 - Prinzip der minimalen Rechtevergabe (Least Privilege Principle)
 - Regelungen für Gast- und externe Zugriffe
2. Umgang mit Daten und Speichermedien
 - Verschlüsselung sensibler Daten (z. B. AES, TLS)
 - Regelungen zur Datenklassifizierung (öffentlich, vertraulich, geheim)
 - Sichere Datenspeicherung und -löschung
3. Netzwerksicherheit
 - Einsatz von Firewalls, VPNs und Intrusion Detection Systems (IDS)
 - Regeln für WLAN-Nutzung und Remote-Zugriff
 - Schutzmaßnahmen gegen DDoS- und Man-in-the-Middle-Angriffe
4. Endgerätesicherheit
 - Verwendung von Antivirensoftware und Endpoint Protection
 - Regelmäßige Updates und Patches für Betriebssysteme und Anwendungen
 - Verbot oder Einschränkung privater Geräte (BYOD-Richtlinien)
5. Incident Management & Notfallpläne
 - Meldewege für Sicherheitsvorfälle und Datenschutzverletzungen
 - Definition von Reaktionsmaßnahmen bei Cyberangriffen
 - Regelmäßige Backups und Disaster-Recovery-Tests
6. Mitarbeitersensibilisierung & Schulungen
 - Schulungen zu IT-Sicherheit & Social Engineering
 - Richtlinien für E-Mail-Sicherheit (Phishing-Erkennung)